

Session 1 — the foundations

Lessons 1 to 4: the mental model, the flows, and how tokens are validated.

Actors & flows

Auth Code + PKCE

Choosing a flow

JWT validation

WHAT SESSION 1 COVERS

1

OAuth Problem, Actors & Endpoints

Why OAuth beats password sharing · the four actors · /authorize vs /token (front- vs back-channel) · tokens, scopes, consent · OAuth vs OpenID Connect

2

Authorization Code + PKCE

The main user flow step by step · request parameters · why PKCE protects the code exchange · state vs redirect_uri vs PKCE

3

Client Credentials, Refresh & Device

Machine-to-machine (no user) · refresh tokens & rotation · device flow for CLI/TV · choosing the right flow

4

Token Validation & JWT Basics

JWT claims (iss, aud, exp, scope) · decoding ≠ validation · the validation checklist · 401 vs 403 · opaque tokens & introspection

After Session 1 you can: explain OAuth without JWT, draw Auth Code + PKCE from memory, pick the right flow, and validate a JWT for the right reason.

SESSION 2 — DATE TO BE ANNOUNCED

Lesson 5 JWS, JWE, JWK / JWKS — signing vs encryption, key rotation

Lesson 6 OAuth security controls — attacks mapped to mitigations

Lesson 7 Advanced: PAR, JAR, JARM, DPoP, mTLS

Lesson 8 FAPI 2.0 — strict OAuth for high-value APIs

Session 1 date: _____ **Format:** in-person / online **Register:** _____